

Intrusion Detection System

Introduction to Intrusion Detection System

What is IDS?

- Software/hardware systems that automate the process of monitoring the events on a computer system/network, analyzing for security

Types of Intruders

- Masquerader "outsider"
 - not authorized to use the system & penetrates access controls to exploit legit user's account
- Misfeasor "insider"
 - legit user accessing resources he is not authorised to, or misuse privileges
- Clandestine user "insider or outsider"
 - takes admin control of system & uses it to avoid detection

Intruder Skill levels

- Apprentice "script kiddies"
 - minimal tech skills who use existing attack tools
 - comprise the largest # of attackers
 - easiest to defend against
- Journeyman
 - sufficient tech skills to modify/extend existing toolkits
 - may be able to locate new vulnerabilities
- Master
 - high skills, can write new toolkits
 - hard to defend against, employed by governments/organizations

Examples of Intrusion

- remote root/admin access
 - aim is to compromise the service
- defacing web server
 - put something on website, make organization look bad
- guess/obtain passwords
- copy databases containing private info
 - credit card #, SSN
- view sensitive data
 - medical info, financial info
- capture network packets
 - obtain usernames/passwords

Intruder behavior

- cracker/hacker
 - motivated by thrill of access and/or status
- criminal enterprise
 - motivated by \$ and/or political/religious, avoid publicity
 - corporations, government funded
- internal threat
 - motivated by revenge/entitlement
 - difficult to detect

Intrusion techniques

- exploit flaws in software
- acquire protected info

IDS requirements

- run with minimal human supervision
- recover from system restarts / crashes
- monitor itself & detect attacks on itself
- minimal overhead on system
- configurable according to system security policies
- scale to monitor large # of hosts
- still (partially) work if some components go down

Intrusion Detection Types

Host-based IDS

- monitor single computer

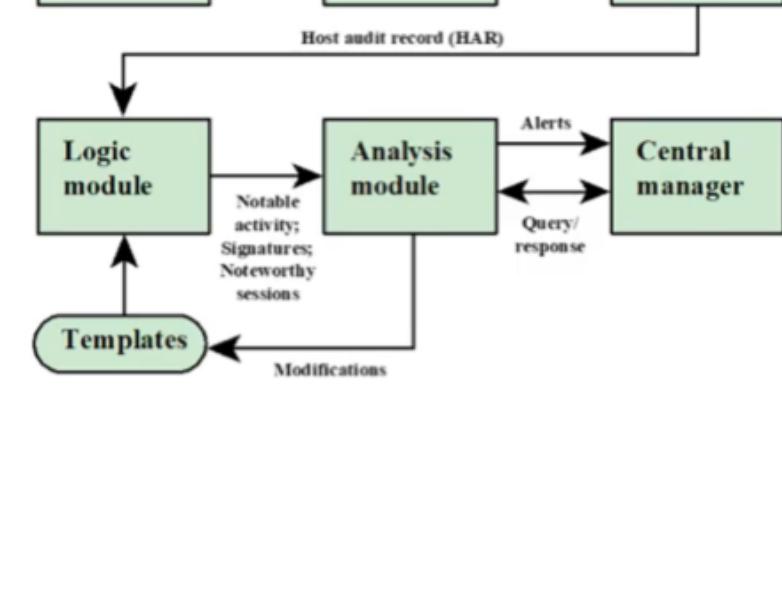
Distributed Host-based IDS

- monitor set of computers with central module detecting intrusions
- uses organization LAN or internetwork
 - host agent collects & analyze audit records
 - LAN monitor agent analyzes LAN traffic
 - host & LAN agents send alerts to central manager
 - central manager combines data to detect intrusion

issues

- deal with different audit record formats
- data over network by agents must be secured
- with central architecture, single point of failure
- with distributed architecture, complex coordination involved

Host agent module



Network-based IDS

- monitor network traffic to identify sus activities
 - monitor traffic at selected points on network using sensors
 - analyze traffic to detect intrusion detection
- Inline sensor "online mode"
 - inserted into network, analyze traffic passing through sensor
 - runs as software on existing switch, router or fw
 - can prevent attack as soon as detected
- Passive sensor "offline mode"
 - monitors copy of traffic
 - extra device that gets copy of traffic eg. switch port mirroring
 - minimal impact on performance of traffic

SNORT

- free to use host-based IDS
 - real time traffic analysis
 - packet logging
- can be configured as sniffer, packet logger and NID

Action	Description
alert	Generate an alert using the selected alert method, and then log the packet.
log	Log the packet.
pass	Ignore the packet.
activate	Alert and then turn on another dynamic rule.
dynamic	Remain idle until activated by an activate rule; then act as a log rule.
drop	Make iptables drop the packet and log the packet.
reject	Make iptables drop the packet, log it, and then send a TCP reset if the protocol is TCP or an ICMP port unreachable message if the protocol is UDP.
sdrop	Make iptables drop the packet but does not log it.

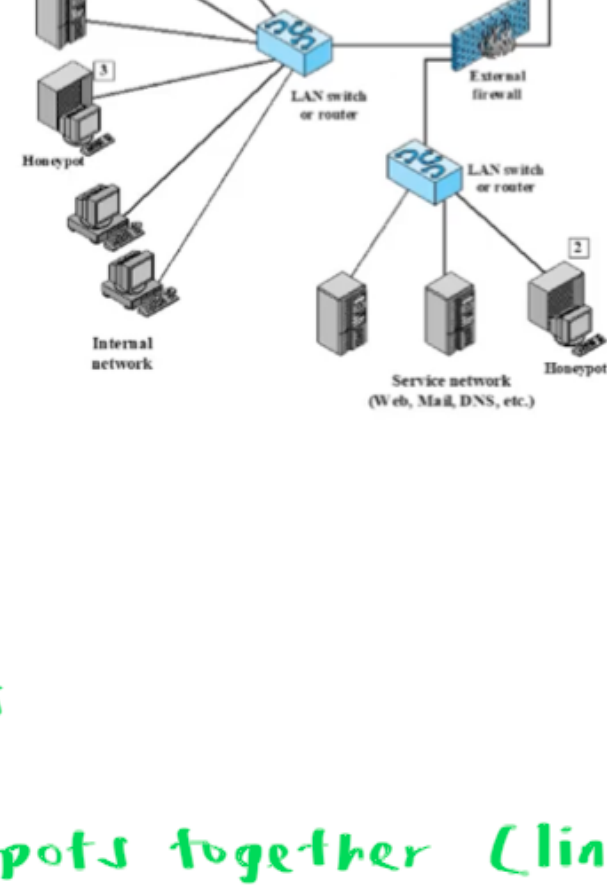
Honey pots

What are honeypots?

- system left intentionally vulnerable
 - default settings, missing patches, security misconfig
 - fake data placed on the Honey pot
- intended to mimic likely targets of cyberattacks
- used to gain info on how attackers operate
- can be used to detect attacks or deflect them from legit targets
- designed to:
 - turn attacker away from critical systems
 - encourage attacker to stay on honeypot long enough for admin to respond

Honey pot deployment

- one outside fw
- one after fw
- one after sw/router



HoneyNets

- two or more honeypots
- group dissimilar honeypots together (linux, windows servers)
- IDS honeynet config sends notification to security admin

Honey Drive

- it is a linux distro, lets you record intruder activities

Honey Files

- act like legit documents with realistic, enticing names
- mainly tries to catch internal intruders